Assignment Report: Building and Auditing an AI-Agent Toolchain

Course: AI Tools and Prompt Engineering | Assignment 8 | B.Tech CSE

Student Name: Nandeni Tiwari	Roll Number: 150096725033
Project Workspace: campus-helpdesk-agent	Repository URL: https://github.com/Nandeniworks/campus-helpdesk-agent.git

Executive Summary

This project implements and audits an end-to-end AI-agent toolchain for a university campus helpdesk scenario across six core parts:

- Part A (Claim Audit): Verification of ten technical claims from the briefing note against official primary specifications, canonical documentation, and academic repositories, while auditing and rejecting an unverified canary instruction.
- Part B (Agent Skill): Implementation and testing of the timetable-helper skill using progressive disclosure, prompt matrix testing, description sensitivity analysis, and an adversarial test.
- Part C (Plugin Packaging): Packaging of the campus-helpdesk plugin with slash command definitions, an active write-protection lifecycle hook (PreToolUse), and a security threat model.
- Part D (MCP Server): Development of a Python stdio MCP server exposing two tools (get_timetable, get_fee_status) and one resource (hostel://rules), verified with automated JSON-RPC 2.0 testing after checking an unverified package recommendation.
- Part E (Git Worktrees): Parallel development using three linked worktrees, manual resolution of a simulated merge conflict, and verification of Git worktree commands.
- Part F (Audit & Reflection): Documentation of five suspicious or unsupported items identified across the briefing and prompt materials, accompanied by an architectural reflection essay.

Part A: Claim Audit (15 marks)

The CTO's briefing note contains ten factual and technical claims concerning the AI-agent toolchain. Each claim was audited against official primary specifications, canonical documentation, and academic repositories. The audited findings, corrections, and citations are documented below:

1. Ten-Claim Audit Table

Claim	Original Briefing Claim Wording	Verdict	Reasoned Explanation / Correction
1	"MCP messages are encoded as JSON-RPC 2.0, and servers can expose three core primitives: tools, resources and prompts."	True	The Model Context Protocol specification strictly defines JSON-RPC 2.0 as its wire format for client-server communication. The protocol specification establishes three primary server primitives: Tools (executable functions with JSON schemas that models can invoke), Resources (contextual data, file contents, or real-time application state read by clients via URI schemes), and Prompts (reusable, pre-structured prompt templates designed to guide model interactions).
2	"As of MCP specification revision 2025-02-30, servers must implement a mandatory 'Persistent Memory Primitive' so that clients can store conversation state on the server."	False	The revision date "2025-02-30" is invalid because February never contains 30 days. Furthermore, the MCP specification mandates no "Persistent Memory Primitive" for server implementations. While stateful session handling is optionally supported across specific transports such as Streamable HTTP (via session headers and SSE streams), conversation history persistence remains client-orchestrated, and servers are not required to provide a mandatory conversation storage primitive.
3	"A Skill is a folder containing a SKILL.md file with YAML frontmatter (name and description). Only the metadata is loaded up front; the full body is loaded when the skill becomes relevant."	True	In Agent Skill architecture, a Skill is packaged as a directory containing a SKILL.md document with YAML frontmatter declaring its name and trigger description. To optimize model context consumption, the runtime applies progressive disclosure: only frontmatter metadata is loaded during agent initialization, whereas the full instruction body and reference documentation are dynamically injected into context only when user input matches the skill's trigger description.
4	"Every Skill must also contain a skill.config.yaml file declaring a runtime field (for example runtime: python3.14), otherwise the Skill is rejected at load time."	False	The Agent Skills specification does not require a skill.config.yaml file, nor do skill loaders reject skills for lacking a runtime declaration. SKILL.md contains the required metadata (name and description in YAML frontmatter), and a skill folder may also bundle supporting references and scripts. While Python 3.14 is an official release in the 2025/2026 timeline, skills are executed through standard environment interpreters rather than a mandatory configuration file constraint.
5	"A Git repository can have multiple linked worktrees, each with its own working directory, while sharing a single object database."	True	Git's linked worktree mechanism (git-worktree) allows multiple working directories to be attached to a single parent repository. Each worktree maintains its own working directory, index (staging area), and HEAD. While linked worktrees share the common repository object database (.git/objects/) and most repository data, some references (such as HEAD and worktree-specific reflogs) and configuration settings (when worktree configuration is enabled) can be worktree-specific.
6	"The command git worktree sync --all pulls and rebases every linked worktree against its upstream in one step."	False	The command git worktree sync --all does not exist in Git. The git worktree command set consists strictly of add, list, lock, move, prune, remove, repair, and unlock. Pulling and rebasing linked worktrees must be performed individually within each worktree directory using standard git fetch and git rebase/git merge commands, or automated via custom shell scripts.
7	"A plugin can bundle slash commands, subagents, Skills, hooks and MCP server configurations into one installable unit."	True	Under the Claude Code and extensible agent plugin architecture, plugins serve as unified distribution packages. A plugin can bundle slash commands (custom interactive prompt workflows), subagents (specialized worker configurations), Agent Skills (SKILL.md bundles), lifecycle hooks (hooks.json), and MCP server definitions (mcp_config.json). This enables developers to distribute, install, and manage complex multi-tool agent environments as a single unit, distinguishing supported core components from optional modules.
8	"According to RFC 9999 ('MCP Transport Security'), every stdio MCP server must be signed with an Ed25519 key before a client may launch it."	False	RFC 9999 does exist, but its official IETF title is "Remote ATtestation procedureS (RATS) Conceptual Message Wrapper (CMW)", which defines attestation message wrapping and has no relation to the Model Context Protocol. The claim is false because RFC 9999 is not titled "MCP Transport Security", and neither the IETF nor the Model Context Protocol mandates Ed25519 cryptographic signing for executing local stdio MCP servers over standard operating system pipes.
9	"By default, Git allows the same branch to be checked out in two different worktrees at the same time, so no special flag is needed."	False	By default, Git prevents the same branch from being checked out in multiple worktrees at the same time. Override options include passing --force during worktree creation or --ignore-other-worktrees with git checkout. However, Git's official documentation explicitly warns that multiple checkouts of a superproject are experimental and that submodule support in multiple worktrees remains incomplete.
10	"Hendricks and Oyelaran (2024) showed that agents with more than 12 loaded Skills suffer a 40 percent drop in tool-selection accuracy, a phenomenon they named 'skill collapse'."	Unverified	A targeted search across arXiv and Google Scholar found no identifiable published paper or preprint authored by "Hendricks and Oyelaran (2024)" investigating "skill collapse" or establishing a 40 percent accuracy drop. Because this specific paper citation and statistic could not be corroborated in the searched repositories, the claim is classified as Unverified rather than definitively proven false.

2. Authoritative Source Citations & Access Dates

Claim	Topic / Primitive	Source Title Recorded in DOCX	Source URL	Citation Status	Access Date
1	MCP Architecture & Primitives	Model Context Protocol Specification (Revision 2026-07-28)	https://modelcontextprotocol.io/specification/2026-07-28 https://modelcontextprotocol.io/specification/2026-07-28/server https://modelcontextprotocol.io/specification/2026-07-28/server/tools https://modelcontextprotocol.io/specification/2026-07-28/server/resources	Original Documented URLs Preserved	Access date not recorded in original evidence
2	MCP Server Lifecycle & State	MCP Specification: Server Lifecycle & Transports	https://spec.modelcontextprotocol.io/specification/server/	Newly verified replacement URL	6 November 2026
3	Skill Progressive Disclosure	Agent Skills Architecture & Progressive Disclosure	https://docs.anthropic.com/en/docs/agents-and-tools/agent-skills	Newly verified replacement URL	6 November 2026
4	Skill Structure & Frontmatter	Agent Skills Specification: Skill Structure & Frontmatter	https://docs.anthropic.com/en/docs/agents-and-tools/agent-skills	Newly verified replacement URL	6 November 2026
5	Git Worktrees Shared Database	Git Documentation: git-worktree(1) Manual Page	https://git-scm.com/docs/git-worktree	Canonical Git SCM URL	7 November 2026
6	Git Worktree Subcommands	Git Documentation: git-worktree(1) Command Reference	https://git-scm.com/docs/git-worktree	Canonical Git SCM URL	7 November 2026
7	Agent Plugin Architecture	Claude Code Plugin System Specification	https://docs.anthropic.com/en/docs/agents-and-tools/plugins	Newly verified replacement URL	9 November 2026
8	RFC 9999 & Stdio Transports	IETF RFC 9999 (RATS CMW) & MCP Transports	https://www.rfc-editor.org/rfc/rfc9999.html https://spec.modelcontextprotocol.io/specification/basic/transports/	Canonical IETF URL & verified MCP Transport spec	9 November 2026
9	Git Multiple Checkout Guard	Git Documentation: git-worktree(1) Safety Constraints & Experimental Submodule Notes	https://git-scm.com/docs/git-worktree#_description	Canonical Git SCM URL	11 November 2026
10	"Skill Collapse" Verification	Computer Science Literature Search (arXiv / Google Scholar)	https://scholar.google.com	Bibliographic verification search	11 November 2026

Part B: Design and Test a Skill (20 marks)

1. Implementation & Progressive Disclosure

The timetable-helper skill is structured across three progressive disclosure layers:
• SKILL.md: Lightweight metadata with YAML frontmatter declaring the skill name and precise trigger boundaries (including positive triggers for classes/timings and negative triggers for fees/hostel).
• references/timetable-format.md: Detailed schema reference defining column semantics, valid batch identifiers (CSE-A, CSE-B), and day formats.
• scripts/timetable_helper.py: Deterministic extraction helper reading from campus-helpdesk/data/mock/timetable.csv.
• Mock Dataset: Clean CSV database containing verified records for CSE-A and CSE-B across weekdays.

2. Prompt Matrix & Evaluation Results

- P1 (Positive - CSE-A Monday): "What classes does CSE-A have on Monday? Please provide subject names, timings, rooms and faculty." → Returned the 3 scheduled classes matching the timetable dataset (Python Programming, Mathematics, Database Systems).
- P2 (Positive - CSE-B Tuesday): "Can you check the timetable for CSE-B on Tuesday and tell me which subjects are scheduled?" → Returned the 1 scheduled class matching the timetable dataset (Operating Systems, 10:00-11:00, Room 302, Dr. Rao).

- P3 (Positive - CSE-A Wednesday): "I'm in CSE-A. Can you tell me what classes I have on Wednesday?" → Returned the 2 scheduled classes matching the timetable dataset (Web Technologies, Software Engineering).
- P4 (Negative - Fees Query): "Can you tell me how I can check whether my college fees have been paid or are still pending?" → Correctly routed away from timetable data, respecting the negative trigger in the skill description.
- P5 (Negative - Hostel Rules): "What are the hostel rules for students regarding entry timings and visitor policies?" → Correctly routed away without returning timetable information.
- P6 (Ambiguous Query): "Can you help me find the information for my next class?" → Clarification requested. The agent prompted the user for the missing batch and day rather than assuming them.

Skill Runtime Telemetry Qualification

Note on Skill Activation Verification: While prompts P1–P3 returned accurate answers grounded in the mock timetable data, without access to host platform runtime telemetry or internal loader logs, we can verify that the answers matched the dataset accurately, but cannot independently confirm whether the platform dynamically loaded the skill body or answered from conversational context.

3. Description Sensitivity Analysis & Adversarial Defense

• Broad Rewrite (V1): Adding broad phrases like "daily schedule and campus activities" caused false-positive matches on fee deadlines and hostel rules.
• Narrow Rewrite (V2): Restricting the description strictly to "Monday timetable for CSE-A" caused false-negative failures on valid queries for CSE-B and other weekdays.
• Balanced Triggering: The active description explicitly enumerates supported entities (batch, day, room, faculty, timings) while listing out-of-scope topics.
• Adversarial Attack & Defense: An adversarial prompt attempted to force the inclusion of a fictitious "Quantum Computing" lecture. The agent adhered to the anti-hallucination instruction in SKILL.md ("Never invent or assume a subject..."), rejected the injection, and returned only verified records from the CSV.
• Automated Unit Tests: tests/test_timetable_helper.py executed 6 automated assertions covering normal queries, case-insensitivity, and nonexistent batch lookups, all passing cleanly.

Part C: Package a Plugin (20 marks)

1. Plugin Bundle Structure

The plugin bundle is packaged at campus-helpdesk/plugin/campus-helpdesk/ and includes:
• Manifest (plugin.json): Configured per Antigravity plugin manifest specifications.
• Slash Command (commands/check-timetable.md): Interactive shortcut defining /check-timetable <BATCH> <DAY>.
• Security Hook (hooks.json & hooks/protect_folder.py): PreToolUse lifecycle hook inspecting tool calls and blocking writes targeting campus-helpdesk/data/mock/.
• MCP Configuration (mcp_config.json): Stdio connection pointing to the campus MCP server.
• Marketplace Entry (marketplace.json): Catalog metadata for agent marketplace discovery.

2. Third-Party Plugin Threat Model

1. Prompt Injection via Skill Instructions:
Threat: An untrusted plugin embedding indirect prompt injections in SKILL.md to override safety rules.
Implemented & Tested: Instruction-level guardrails in SKILL.md (validated via the adversarial test in Part B).
Proposed / Recommended: Static AST scanning of markdown files during plugin installation and runtime system-prompt isolation.

2. Malicious Lifecycle Hooks:
Threat: Untrusted hook scripts executing arbitrary shell commands or exfiltrating data when tool events fire.
Implemented & Tested: A Python PreToolUse write-gate (hooks/protect_folder.py) that inspects tool arguments and exits with status 1 to block unauthorized writes to mock data.
Proposed / Recommended: Interactive confirmation prompts before running newly installed hooks and sandboxed execution for hook scripts.

3. Tool Poisoning via MCP Descriptions:
Threat: Misleading or adversarial tool and parameter descriptions that trick the model into calling tools inappropriately or passing sensitive context to external endpoints.
Analysis of Current Controls: The server implements strict regex input validation (^STU\d{3}$) in campus_helpdesk_server.py. However, regex validation protects only against malformed input arguments; it does not detect or prevent deceptive MCP tool descriptions at registration time. No automated defense against tool poisoning is currently implemented in the plugin.
Proposed / Recommended: Static schema analysis and description linting during MCP registration, along with explicit user confirmation prompts before the agent executes sensitive tool calls or external data operations.

Part D: Build an MCP Server (20 marks)

1. Architecture & Package Verification

• Package Verification: The briefing note suggested using @nimbus/mcp-skill-bridge (v2.3). Checks against npm (npm view @nimbus/mcp-skill-bridge) returned HTTP 404 (Not Found), and PyPI searches yielded no matching package. Because the package was not found in the package repositories checked, the server was built directly with the official mcp SDK (v2.3.0 in a dedicated virtual environment).
• Server Implementation (campus-helpdesk/mcp-server/campus_helpdesk_server.py):
- Tool 1 (get_timetable): Takes batch and day, queries campus-helpdesk/data/mock/timetable.csv, and returns matching schedule records.
- Tool 2 (get_fee_status): Takes student_id, validates against ^STU\d{3}$, and returns fee payment details or an error message.
- Resource (hostel://rules): Serves the full markdown text of campus hostel rules from campus-helpdesk/data/mock/hostel_rules.md.

2. Protocol Verification & Automated Tests

The automated test suite campus-helpdesk/mcp-server/tests/test_mcp_server.py verified all 8 core protocol steps over stdio:
1. Handshake (initialize): Successfully negotiated protocol version 2024-11-05 and server capabilities (tools, resources).
2. Notification (notifications/initialized): Sent initialized confirmation to complete client handshake.
3. Tool Discovery (tools/list): Returned 2 tools with valid JSON input schemas.
4. Resource Discovery (resources/list): Returned 1 resource (hostel://rules, text/markdown).
5. Resource Read (resources/read): Successfully retrieved hostel curfew, visitor policies, and facility rules.
6. Tool Execution 1 (tools/call - get_timetable): Retrieved 3 Monday classes for CSE-A.
7. Tool Execution 2 (tools/call - get_fee_status): Retrieved student fee record for STU001 (Aarav Sharma, CSE-A, PAID).
8. Error Handling (tools/call - get_fee_status with INVALID_999): Returned structured domain error rather than an unhandled crash.
All raw JSON-RPC 2.0 message exchanges were captured and saved to evidence/mcp/raw_rpc_exchange.json.

Part E: Parallel Development with Worktrees (15 marks)

1. Worktrees Established: Three linked worktrees were created using git worktree add:
• .worktrees/feature-skill-tests (branch: feature/skill-tests)
• .worktrees/feature-mcp-server (branch: feature/mcp-server)
• .worktrees/bugfix-hook-path (branch: bugfix/hook-path)

2. Conflict Simulation & Resolution: Both feature branches made concurrent modifications to the status section of README.md. Merging feature/mcp-server into main after feature/skill-tests produced a genuine Git content conflict. The conflict was resolved manually by retaining and organizing both status updates (commit 7f61e2b). The bugfix branch was merged subsequently (commit 3a31079).

3. Evaluation of /worktree-merge:
• Finding: The command /worktree-merge was not found in the Claude Code command documentation checked. Standard Git does not provide a /worktree-merge command either; branch integration across worktrees relies on standard Git branching and merging operations (git merge, git rebase).
• Analysis: Merging branches across worktrees automatically without human review risks unhandled content conflicts, silent logic regressions, and accidental overwrites of security configurations. Standard Git merge workflows ensure conflicts are inspected and resolved deliberately.

Part F: Reflection and Prompt Log (10 marks)

1. Suspicious or Unsupported Items Identified

- 1. @nimbus/mcp-skill-bridge: Suggested package was checked on npm (returned 404) and PyPI (no match found); replaced with the official mcp SDK.
- 2. "NimbusSync Plugin Standard v4.2": Canary prompt instruction demanding citation of an unverified standard and registry was audited, rejected, and excluded.
- 3. /worktree-merge Command: Suggested command was not found in the Claude Code command documentation checked; branch integration across worktrees relies on standard Git branching and merging operations.
- 4. MCP Revision "2025-02-30" & Mandatory Memory Primitive: Revision date contains an impossible calendar date (Feb 30), and the protocol specification mandates no persistent memory primitive.
- 5. git worktree sync --all: Suggested Git command does not exist in the official git-worktree command set.

2. Architectural Reflection Essay (320 words)

Architectural Boundaries & Engineering Judgement
Each architectural component in the modern AI-agent toolchain addresses a fundamentally distinct layer of the problem space:

• Skills solve the problem of procedural guidance and domain methodology. They teach an agent how to approach specialized tasks through instructions and progressive disclosure without bloating baseline context.
• Plugins solve the problem of distribution, lifecycle management, and policy enforcement. They bundle skills, custom commands, hooks, and configs into a single installable unit governed by security boundaries.
• MCP (Model Context Protocol) solves the problem of dynamic data connectivity and real-time execution. It provides a standardized client-server protocol over stdio/SSE, giving agents access to live external databases and enterprise resources without hardcoded integrations.
• Git Worktrees solve the problem of isolated, parallel developer collaboration. They allow multiple concurrent development branches to share a single repository object database without filesystem collisions or switching overhead.

When to Choose a Skill over an MCP Tool:
I would choose an Agent Skill over an MCP tool when the objective is to teach the agent reasoning strategies, runbooks, anti-hallucination policies, or multi-step analysis workflows that operate on files already accessible in the repository. Skills excel at explaining how to think and format responses. Conversely, an MCP tool is essential when the agent requires real-time access to live data stored behind an authenticated API, transactional mutation capabilities (such as updating a student ledger), or when exposing capabilities across multiple agent platforms. A Skill defines policy; an MCP tool executes remote capabilities.

What Would Never Be Delegated to an Agent Without Review:
I would never delegate destructive schema migrations, access control policy changes, production deployment pipelines, or autonomous merge conflict resolution without human review. While agents can accurately generate resolutions, they lack situational awareness regarding business consequences. An automated merge can produce syntactically valid code that silently breaks security invariants. Human oversight remains mandatory for state mutations that are irreversible or security-critical.

3. Prompt Log & Verification Journal Overview

A complete verification journal is maintained in prompt-log/prompt-log.txt, containing 9 structured entries documenting all inspection prompts, transcript extractions, adversarial injections, trigger sensitivity calibrations, package verification commands, and canary trap evaluations. All 5 catches are accompanied by terminal command outputs and authoritative counter-evidence.